

Computer and Network Security

Lab 03 (“Unmasking the Network”)

Disclaimer. Hacking without permission is illegal. These labs are strictly educational for learning about cyber-security in the areas of ethical hacking and penetration testing so that we can protect ourselves against the real hackers. Hence, any attack technique, tools, and technology, learned during these labs should only be launched on systems you either own or have permission to launch attacks on. Don't wrong your classmates by launching attacks against them—they will know in the judgement day and you will pay for that. Please be professional, wise, and mature.

Lab Note. In Lectures 3, you have learned the attack anatomy—from reconnaissance to covering tracks. When attackers want to target a specific network infrastructure, they start by performing reconnaissance, which is collecting information about the target infrastructure. They may follow a passive, active, and/or hybrid approach. In the passive mode, the attacker collect information about the target system without actively engaging with the target's subsystems. They may watch building to see what time employees enter/leave, google individual and browse company website, sniff network traffic for IP addresses, IP address range, naming conventions, hidden servers and services, etc. The active approach involves direct interaction with the target's infrastructure. It involves identifying individual hosts, IP addresses, operating systems, services, open communication ports, ..., and performing some social-engineering.

Description. In this lab, you will learn how attackers perform reconnaissance in a cyberattack. You'll use various tools to perform information gathering about target systems. This will allow you to think about defensive measures to protect your institutions, company, start-up, etc. You will be using tools like Google's search engine algorithm, git, sherlock, blackbird, theHarvester, metagoofil, whatweb, nslookup, whois, dig, ping, traceroute, netdiscover, nmap, hping3, nikto, and blackwidow.

Task 1 (Passive Reconnaissance)

During passive reconnaissance, attackers perform **footprinting**, which is the process of gathering all available information about the target (i.e., creating the blueprint of a target system). The collected information can later be used in a social-engineering attack to gather additional information about the target.

1. **Google Dorking.** This technique, a.k.a., Google hacking, uses the Google search engine with special keywords to collect information about a target system. Try the following:

- **intitle:"ensia"** will display links to webpages that contain the keyword “ensia” in the title section of the webpage.
- **intext:"ensia"** will display links to webpages that contain the keyword “ensia” in the body section of the webpage.
- **filetype:pdf** will display links to pdf-files. However, if you use it directly, Google will not respond to you as you are almost requesting something infinite. To be concise, combine the **filetype** operator with an **intitle** or **intext** operator to obtain results. Try the combination **filetype:pdf intext: "ensia"**. It will display links to pdf-files that contain the keyword “ensia”.
- **site:"ensia.edu.dz"** will display resources related to the site or domain of ENSIA. Try the combination **site:"ensia.edu.dz" filetype:pdf** to get all pdf files stored in the ensia webserver (e.g., CVs of faculty members).
- **inurl:"ensia"** will display links to webpages that contain the keyword “ensia” in URL (Uniform Resource Locator) of the webpage.

🔗 Use Google dorking to find the CV of Dr. Karim Lounis. Also, there is a CV that is stored on the school’s website folder and that is not accessible through the school’s website faculty members page. Use Google dorking to find it.

As a conclusion, Google dorking allows you to quickly prompt the Google’s search engine for specific webpages and pdf files. So, instead of going through the website looking for specific webpages and documents, Google dorking allows you to automatically scrap websites and identify hidden URIs, and find important files that are hard to get through normal search engine usage.

2. **Social Media Username Hunting.** This technique uses tools such as **sherlock** or **blackbird** to find a specific username on social media accounts. For this task, we are setting out target to be **Boubarita ElHacker**. Install **sherlock** on Kali GNU/Linux (**sudo apt install sherlock**), or clone the repository from GitHub [here](#). Then, run the tool on the username **boubarita**. This should display social media accounts were this nickname is used. It scans for 300 social media platforms (it is pretty slow). To speed up, you may use **blackbird**. You can get it from [here](#) (it runs faster than sherlock).

Social Media	Profile picture
--------------	-----------------

Airliners.net	
Myspace.com	
moto-trip.com	
flipboard.com	
metacritic.com	
X.com	
github.com	

.

Use both tools to verify whether **Boubarita ElHacker** uses one of the social media platforms cited in the above table. Also, try to learn as much information as possible about him. Make use of his profile picture.

3. **Information Harvesting.** This technique uses tools such as **theHarvester**, **Metagoofil**, and **whatweb** to harvest information from specific source.

3.1. **theHarvester:** At its core, **theHarvester** (repo [here](#)) is a modular python script that acts as an aggregator for Open Source Intelligence (OSINT). It gathers information about domains by asking passive scrapers like search engines and connecting “through APIs” to specialized databases like Shodan (for open ports), Hunter.io (for corporate emails), or crt.sh (for SSL certificate logs). Yet, most of the built-in “free” scrapers (like the Google or Bing modules) are now effectively dead because of CAPTCHAs and bot detection. Hence, the output from **theHarvester** is expected to be less interesting than it used to be.

- Run **theharvester -d ensia.edu.dz -b all** to use all the tool’s sources to find email addresses, running hosts, of the domain **ensia.edu.dz** (it will take a minute). You can see from the output that there are many “Missing API key” messages. The output would be much richer if we had the keys.

3.2. **Metagoofil**: Metagoofil is an OSINT reconnaissance tool designed to find and download public documents (PDFs, Word docs, Excel sheets, etc.) from a target domain and extract metadata from them. Sometimes, the website administrator of a company leaves important files in the website folder, even though they are not referenced in the website (i.e., accessible from the website).

- On Kali Linux the tool is pre-installed (if not: `apt install metagoofil`). On other distributions you may need to clone the repo from [here](#). Run the tool by typing `metagoofil`. If you cloned the repo, use python to run it.
- Execute `metagoofil -d ensia.edu.dz -t pdf` to find PDF files that were indexed by Google's search engine crawlers and that are stored on the given domain servers. If the tool returns void, then that is totally normal due to Google's aggressive bot protection which they recently enforced.

3.3. **whatweb**: This tool is a website scanner. It uses thousands of plugins to scan a target website and look for HTTP headers, HTML source, cookie names, URL paths, etc. You should expect limited results due to security measures.

- On Kali the tool is pre-installed (if not: `$apt-get install whatweb`). Run: `whatweb https://www.ensia.edu.dz`. Also, run the same command on `whatweb https://ensia.edu.dz`. Analyze the output— what did you learn? You may prompt an LLM to interpret your results.

Task 2 (Active Reconnaissance)

During active reconnaissance, attackers perform **scanning and enumeration**, which is the process of systematically scanning the target's network to identify active devices, open ports, operating systems (OS fingerprinting), and services. The collected information can be used in a social-engineering attack to gather additional information.

1. **DNS Enumeration.** This is the process of locating all the DNS servers and their corresponding records for a given domain or organization. Our case: `ensia.edu.dz`.

3.1. **Nslookup**: (Resolve domain names and retrieve DNS records)

- The **NSlookup** tool queries DNS servers for their records.

- Run `nslookup www.ensia.edu.dz`. This should return the A-record, which maps “www.ensia.edu.dz” to its corresponding IPv4 address.
- Run `nslookup -type=aaaa www.google.com`. It returns the AAAA-record containing the IPv6 address of the Google’s web-search engine.
- Run `nslookup -type=soa ensia.edu.dz 8.8.8.8`. This means you are asking the Google’s DNS public resolver 8.8.8.8 to resolve the domain ensia.edu.dz and return the soa record (start of authority record).
- Run `nslookup -type=mx ensia.edu.dz 1.1.1.1`. This means you are asking Cloudflare’s DNS public resolver 1.1.1.1 to get you the mx record (mail exchange record) of the domain **ensia.edu.dz**.

3.2. Whois: (Retrieve information about domains from Whois database)

- The **whois** tool queries a DB for information about domain names.
- Run `whois -h whois.iana.org google.com` to retrieve info about who maintains **google.com** and **.com** (administrative & technical bureaus), when it was created, when it expires, name servers, registrant country, etc.
- Try the following domains: **mobilis.dz**, **djezzy.dz**, and **oreedoo.dz**.

3.3. dig: (Resolve domain names and retrieve DNS records — same as nslookup)

- The **dig** tool queries DNS servers for their records.
- Run `dig www.ensia.edu.dz +short`. This should return the A-record, which maps “www.ensia.edu.dz” to its corresponding IPv4 address.
- Run `dig ns ensia.edu.dz +short`. This should return the NS-record, which maps “ensia.edu.dz” to its domain name servers.
- Run `dig mx ensia.edu.dz +short`. This should return the MX-record, which maps “ensia.edu.dz” to its domain mail exchange servers.
- Run `dig -x 41.111.152.146` to get with which IP address a domain name is associated with This should retrieve the PTR DSN records.

You can also try [this](#) website for additional information.

2. Network Discovery. This aims to discover the components of a target network, trying to identify the IP addresses, address range, MAC addresses, routes, etc.

2.1. **ping**: (Test connectivity and get RTT)

- **ping** is a networking tool that comes pre-installed.
- Run `ping www.ensia.edu.dz`. Discuss the output.

2.2. **traceroute**: (Trace possible route to destination)

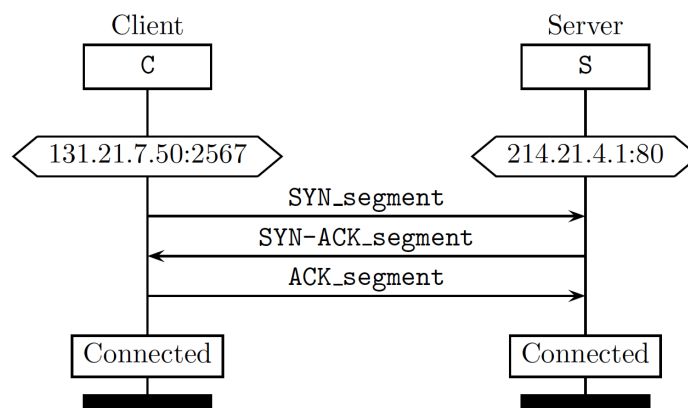
- **traceroute** come also pre-installed.
- Run `traceroute www.ensia.edu.dz` to obtain the IP addresses of some computers that situated between your computer and the ensia webserver.
- You may obtain some private IP addresses. Explain why.
- You may also get “* * *” instead of IP addresses. What are those?

2.3. **netdiscover**: (Discover computers in your local network)

- **netdiscover** may need to be installed (`$apt install netdiscover`).
- Run `netdiscover -r 192.168.0.0/24` to obtain the IP addresses and MAC addresses of computers connected in your local network.

3. **Port Scanning and OS Fingerprinting**. This aims to discover open ports and running services. It also aims at finding out which operating system the target system runs.

The most common and efficient tool for port scanning and OS fingerprinting is **nmap**, which is a free open-source tool. Before jumping into **nmap**, let us have a quick recall of how a TCP connection is initiated between a client and a server. The figure below illustrates the TCP three-way-handshake (3 TCP segments are exchanged to establish a connection).



Port scanning consists of **probing** each port and identifying whether it is open or not. When you scan for port using **nmap**, the tool detects three port states: open (means a service is running and listening on the port), filtered (means that a firewall is preventing responses), and unfiltered (supposed closed). Also, **nmap** supports different types of scan to deal with different types of operating systems and firmware.

You can also use the tool online at: <https://nmap.online/>.

Among the various scanning methods **nmap** performs, is:

- **TCP scan.** This form of scanning tries to establish a full TCP connection on the most common 1,000 ports:

```
nmap -sT 192.168.1.1
```

You can specify the port too:

```
nmap -p 80 -sT 192.168.1.1
```

- **SYN stealth scan.** Start the 3-way-handshake but does not complete it. I.e., does not send the ACK segment. If an SYN-ACK is received, the port is assumed to be open. However, if an RTS is received back, then the port is either not active or closed.

```
nmap -sS 192.168.1.1
```

- **XMAS scan.** Sends a packet with FIN, URG, and PSH flags set. If the port is open, there is no response. If the port is closed, a RST-ACK is received. This scan works only on systems that follow the RFC793 implementation of TCP/IP (e.g., not on Windows).

```
nmap -sX 192.168.1.1
```

- **UDP scan.** Works by sending a UDP packet to every targeted port. For most ports, this packet will be empty (no payload), but for a few of the more common ports a protocol-specific payload will be sent. Based on the response, or lack thereof, the port status is identified.

```
nmap -sU 192.168.1.1
```

3.1. **nmap**: (Discover open ports, running services, and OS fingerprinting)

- Make sure to install **nmap**. On Kali GNU/Linux it comes preinstalled.

- The first step in scanning would be the identification of systems that are up and running. We can perform a **ping sweep** using **nmap** by sending pings to all computers in a given address range. Run: **nmap -sP 192.168.0.1-254**. The issue with this method is that the ICMP packets sent by the tools are blocked by firewalls.
- Run **nmap www.ensia.edu.dz**. This will perform a TCP scan (same with option -sT), i.e., realize a complete 3-way-handshake with the target. Which ports are open?
- Run **nmap -sS -sV -O -n www.ensia.edu.dz**. This will perform fetch for port status, running services, their version and the operating system. Discuss you output?
- You may use different VPNs to avoid being block by the firewall.

3.2. **hping3**: (Discover open ports and running services)

- Make sure to install **hping3**. On Kali GNU/Linux it comes preinstalled.
- Run **hping3 -S www.ensia.edu.dz -p 443 -c 2**, which will transmit two TCP packets with default flags on port 443. Try other ports. Which one are open?
- Run **hping3 -2 www.ensia.edu.dz -p 53**, which will transmit UDP packets with default flags on port 53.

3.3. **p0f**: (Banner grabbing and OS fingerprinting)

- Make sure to install the tool **apt-get install -y p0f**.
- **p0f** is a passive TCP/IP stack fingerprinting tool. It can attempt to identify the system running on remote machines in a local network.
- Run **p0f -i eth0 -p -o /tmp/p0f.log**, will eavesdrop network traffic to detect computers and interact with them to determine their operating system.

4. **Users and Shared Resources Scanning.** In this part, you will use SMB (Server Message Block) client to scan and enumerate users and shared resources. You would need to have a Windows machine (e.g., Windows XP, vista, 7, 8, or 10) to set up as a target.

- On your Kali/Linux machine, run the following commands to discover usernames and shared folders in your local network. This will concern computers running SMB service to facilitate resource sharing within a local network:

```
$smbclient -L 192.168.193.218 -U WORKGROUP/Hacker
```

- Assuming that 193.168.193.218 is the IP address of the target computer, you should obtain the list of shared folders and printers.
- For the list of usernames (i.e., accounts), use the following command to interrogate the NetBIOS (NBT) name table: `$nbtscan -v -r 192.168.1.2`.

5. **Server Vulnerability Scanning.** Here, you are going to use some tools to analyze servers for vulnerabilities.

5.1. **nikto:** (Web server banner grabbing and vulnerability scanning).

With tools like **nikto** you can identify vulnerabilities in a webserver. This helps an attacker to get to know the flaws and weakness of the target web-server.

- Make sure to install **nikto**. On Kali GNU/Linux it comes preinstalled.
- Run `nikto -h 192.168.1.1 -p 443`, will perform active vulnerability scanning and display information such as web server name, version, vulnerabilities. You can try that on the school's website: `nikto -h ensia.edu.dz -p 443`, and also `nikto -h www.ensia.edu.dz -p 443`
- Run `nikto -h 192.168.1.1 -ssl`, will perform active vulnerability scanning and display information about the server, the ssl service, version, and vulnerabilities.

5.2. **blackwidow:** (Web server crawling)

With tools like **blackwidow** you can crawl an entire website and recover all the webpages and documents that are in the website folder.

- Git clone the repo at: <https://github.com/1N3/BlackWidow>.
- Run `blackwidow -u https://www.cerist.dz`, will crawl the entire website to discover URLs, subdomaines, email addresses, phone numbers.
- Run `blackwidow -u https://www.cdta.dz`, will crawl the entire website to discover URLs, subdomaines, email addresses, phone numbers.

- Try the URL: <http://www.ensia.edu.dz>. What do you obtain?

Additional useful links:

- Privacy test: What information can a website find out about you when you visit it. Check this out at <https://privacy.net/analyzer/>.
- Your browser is spitting private information about you to the internet. Check that out here <https://www.whatismybrowser.com/> and here <https://www.whatsmybrowser.org/>.